

TRƯỜNG ĐẠI HỌC CÔNG NGHIỆP HÀ NỘI
TRƯỜNG CÔNG NGHỆ THÔNG TIN & TRUYỀN THÔNG

-----□□□-----

BÁO CÁO THỰC NGHIỆM

Học phần: An ninh mạng

**Chủ đề: Xây dựng mô hình mạng an toàn cho công ty CP kỹ thuật
và công nghệ TMT**

Giáo viên hướng dẫn : TS. Phạm Văn Hiệp

Nhóm sinh viên thực hiện :

1. Nguyễn Đình Trung Mã SV: 2023605232

2. Mã SV: 2020600122

Mã Lớp học phần:

Nhóm: 2

Hà Nội - Năm 2025

MỤC LỤC

Danh mục các từ viết tắt...

Danh mục hình ảnh...

Danh mục bảng biểu...

Lời nói đầu

Chương 1: Tổng quan

-.+. Tổng quan về An toàn bảo mật thông tin

- Khái niệm :An toàn và bảo mật thông tin là tập hợp các biện pháp, kỹ thuật và quy trình nhằm bảo vệ dữ liệu và hệ thống thông tin khỏi các mối đe dọa như truy cập trái phép, sửa đổi, phá hoại hoặc làm gián đoạn dịch vụ. Trong bối cảnh công nghệ số phát triển mạnh mẽ, thông tin trở thành một tài sản quan trọng không chỉ đối với cá nhân mà còn đối với tổ chức, doanh nghiệp và quốc gia.

An toàn bảo mật thông tin hướng tới việc đảm bảo dữ liệu luôn được bảo vệ trước các nguy cơ từ bên trong và bên ngoài, giúp duy trì hoạt động ổn định của hệ thống, giảm thiểu rủi ro và thiệt hại do tấn công mạng gây ra. Vì vậy, đây là yếu tố cốt lõi để xây dựng niềm tin trong các giao dịch điện tử, thương mại số và mọi hoạt động ứng dụng công nghệ thông tin hiện nay.

- Lịch sử phát triển:
 - Khởi nguồn khái niệm bảo mật thông tin
 - Bảo mật trong hệ thống máy tính
 - Bảo mật mạng và Internet
 - An toàn thông tin toàn diện trong kỷ nguyên số

Khái niệm an toàn bảo mật thông tin hình thành và phát triển gắn liền với tiến trình phát triển của công nghệ máy tính và mạng máy tính. Ban đầu, vào những năm 1940-1960, an toàn thông tin chỉ tập trung vào việc bảo vệ các hệ thống máy tính sơ khai, chủ yếu phục vụ mục đích quân sự và khoa học, với biện pháp bảo mật chủ yếu là mã hóa và kiểm soát truy cập vật lý. Đến những năm 1960-1980, khi máy tính đa người dùng và hệ điều hành phát triển, nhu cầu bảo vệ dữ liệu nội bộ giữa các người dùng tăng lên, cùng với đó là sự ra đời của các mô hình bảo mật đầu tiên như Bell-LaPadula. Giai đoạn từ 1980 đến 2000 chứng kiến sự bùng nổ của mạng máy tính và Internet, kéo theo sự xuất hiện của các mối đe dọa mạng như virus, sâu máy tính và tấn công mạng. Điều này thúc đẩy việc ra đời các công cụ bảo vệ như tường lửa, mã hóa kênh truyền và hệ thống phát hiện xâm nhập. Bước sang thế kỷ 21, cùng với sự phát triển của thương mại điện tử, mạng xã hội và công nghệ số, an toàn bảo mật thông tin không chỉ là vấn đề kỹ thuật mà còn trở thành mối quan tâm chiến lược của các tổ chức và quốc gia. Ngày nay, các kỹ thuật bảo vệ dữ liệu hiện đại như trí tuệ nhân tạo, blockchain hay mô hình Zero Trust được ứng dụng rộng rãi, nhằm đối phó với các mối nguy hiểm phức tạp và tinh vi như tấn công có chủ đích hay chiến tranh mạng.

- Mục tiêu của an toàn bảo mật thông tin: chính là bảo vệ dữ liệu và hệ thống thông tin khỏi các tác động gây hư hại, sửa đổi hoặc truy cập trái phép. Thông tin trong an toàn bảo mật gồm 3 thuộc tính thường được gọi tắt là mô hình CIA:

- Tính bí mật (Confidentiality),
- Tính toàn vẹn (Integrity)
- Tính sẵn sàng (Availability),

Tính bí mật đảm bảo rằng thông tin chỉ được phép truy cập bởi những đối tượng có quyền hợp lệ, giúp ngăn chặn việc rò rỉ hoặc nghe lén dữ liệu. Tính toàn vẹn đảm bảo thông tin không bị thay đổi, chỉnh sửa trái phép trong quá trình lưu trữ, xử lý hoặc truyền tải, giúp duy trì độ chính xác và tin cậy của dữ liệu. Tính sẵn sàng đảm bảo rằng người dùng hợp lệ có thể truy cập thông tin và hệ thống bất cứ khi nào cần, không bị gián đoạn bởi lỗi kỹ thuật hoặc các cuộc tấn công gây nghẽn dịch vụ. Ba thuộc tính này là cơ sở để xây dựng mọi giải pháp bảo mật hiện đại, từ mã hóa dữ liệu, xác thực người dùng cho đến hệ thống phòng chống tấn công mạng

1.2. Các kiến thức cơ sở

Trong lĩnh vực an toàn thông tin, việc nắm vững các kiến thức cơ sở về cả lý thuyết lẫn thực tiễn mạng là điều kiện tiên quyết để thiết kế, triển khai và vận hành một mô hình mạng an toàn. Các nội dung nền tảng này bao gồm kiến thức về kiến trúc an toàn thông tin, các cơ chế kiểm soát an ninh và các công cụ, ngôn ngữ hỗ trợ giám sát hệ thống.

1.2.1. Kiến thức cơ sở về an toàn thông tin và an toàn mạng máy tính

a. Kiến trúc phân vùng bảo mật và Mô hình Zero Trust

- Phân vùng mạng (Network Segmentation): Là kỹ thuật cô lập hạ tầng mạng thành các phân khu logic dựa trên mức độ tin cậy và chức năng.
 - + *Vùng Inside*: Mạng nội bộ dành cho nhân viên, đòi hỏi tính bảo mật thông tin cao.
 - + *Vùng Outside*: Mạng Internet công cộng, nơi chứa đựng các nguy cơ tấn công tiềm ẩn.

- + *Vùng DMZ (Demilitarized Zone)*: Vùng đệm trung gian chứa các Máy chủ dịch vụ công cộng (Web, Mail, DNS). DMZ cho phép người dùng Internet truy cập vào các dịch vụ này nhưng ngăn chặn họ kết nối trực tiếp vào mạng Inside.
- + *Vùng Server Farm*: Phân vùng cô lập chuyên biệt để bảo vệ các máy chủ cơ sở dữ liệu và tài nguyên cốt lõi của doanh nghiệp.
- Mô hình Zero Trust: Hoạt động dựa trên ba nguyên tắc cốt lõi: Xác thực liên tục (Verify explicitly), Cấp quyền tối thiểu (Least privilege access), và Luôn giả định hệ thống đã bị xâm nhập (Assume breach). Khác với mô hình biên truyền thống (chỉ bảo vệ vòng ngoài và tin tưởng vòng trong), Zero Trust loại bỏ khái niệm "vùng tin cậy mặc định". Mọi yêu cầu truy cập từ bất kỳ thiết bị hay người dùng nào đều phải được định danh, kiểm tra cấu hình an toàn (Device Health) và cấp quyền truy cập vừa đủ cho phiên làm việc đó.

b. Các giao thức mạng an toàn và Chuyển mạch/Định tuyến

- VLAN (Virtual Local Area Network - IEEE 802.1Q): Công nghệ chia một miền quảng bá (Broadcast Domain) vật lý duy nhất trên Switch thành nhiều miền logic độc lập ở tầng Link Layer. Traffic giữa các VLAN hoàn toàn bị cô lập ở Tầng 2, buộc phải đi qua thiết bị Tầng 3 (Router hoặc Layer 3 Switch) để thực hiện Inter-VLAN Routing, tạo điều kiện tích hợp các chính sách lọc gói tin (ACL).
- Định tuyến và Quản trị an toàn: * *Định tuyến an toàn*: Sử dụng các giao thức định tuyến động có bất tính năng xác thực bắt tay bằng thuật toán MD5 hoặc SHA (như OSPFv2/v3 Authentication). Cơ chế này giúp ngăn chặn kẻ tấn công gửi các gói tin định tuyến giả mạo nhằm chuyển hướng luồng dữ liệu (Route Hijacking).

- + *Quản trị an toàn*: Thay thế toàn bộ các giao thức truyền thông bản rõ (Clear-text) bằng các giao thức mã hóa: sử dụng SSH (Cổng 22) thay cho Telnet, HTTPS (Cổng 443) thay cho HTTP, và SNMPv3 (có mã hóa và xác thực User) thay cho SNMPv2 nhằm triệt tiêu nguy cơ bị đánh cắp thông tin quản trị qua kỹ thuật nghe lén gói tin (Sniffing).

c. Cơ chế dịch biên địa chỉ (NAT/PAT) và Kiểm soát truy cập (ACL)

- NAT/PAT (Network Address Translation / Port Address Translation): Cơ chế ánh xạ một hoặc nhiều địa chỉ IP Private thành một hoặc nhiều địa chỉ IP Public hợp lệ trên Internet. Đặc biệt, PAT (NAT Overload) sử dụng các số hiệu cổng nguồn (Source Port) khác nhau để cho phép hàng nghìn máy tính nội bộ dùng chung một IP Public. Về mặt an ninh, NAT/PAT đóng vai trò như một lá chắn ẩn danh, che giấu hoàn toàn sơ đồ IP nội bộ, khiến tin tặc từ Internet không thể chủ động thiết lập kết nối trực tiếp đến các máy trạm bên trong.
- ACL (Access Control List): Là tập hợp các quy tắc (Rules) được cấu hình trên Router, Layer 3 Switch hoặc Firewall để lọc lưu lượng mạng dựa trên các thông số cấu trúc gói tin bao gồm: IP nguồn, IP đích, Loại giao thức (TCP/UDP/ICMP), và Số hiệu cổng dịch vụ (Port Number). ACL hoạt động theo nguyên tắc so khớp từ trên xuống dưới (Top-Down) và kết thúc bằng một lệnh ẩn **Deny All** (Cấm tất cả những gì không được phép).

1.2.2. Kiến thức cơ sở về tấn công mạng và giải pháp phòng thủ

a. Các hình thức tấn công mạng phổ biến

- Tấn công từ chối dịch vụ (DoS/DDoS): Nhằm vào việc làm tê liệt tính sẵn sàng (Availability) của hệ thống. Kẻ tấn công sử dụng một mạng máy tính ma (Botnet) để gửi đồng loạt hàng triệu yêu cầu giả mạo. Các hình thức phổ biến bao gồm SYN Flood (lợi dụng quá trình bắt tay 3 bước của TCP để làm cạn kiệt bảng kết nối TCB của máy chủ) hoặc UDP/ICMP Flood (làm nghẽn hoàn toàn băng thông đường truyền của doanh nghiệp).
- Tấn công nghe lén và giả mạo (Man-in-the-Middle - MitM): Kẻ tấn công xen vào giữa luồng giao tiếp hợp pháp.
 - + *ARP Spoofing*: Gửi các thông điệp ARP giả mạo vào mạng LAN để ánh xạ địa chỉ MAC của kẻ tấn công với IP của Gateway, từ đó ép toàn bộ dữ liệu của nạn nhân phải đi qua máy kẻ tấn công trước khi ra ngoài.
 - + *DNS Spoofing*: Làm nhiễm độc bộ nhớ đệm DNS, chuyển hướng người dùng từ các trang web hợp pháp (như ngân hàng) sang các trang web giả mạo do kẻ tấn công lập sẵn để đánh cắp thông tin tài khoản.
- Tấn công dò quét và khai thác lỗ hổng (Scanning & Exploitation): Giai đoạn đầu của mọi cuộc tấn công, sử dụng các công cụ tự động để quét cổng (Port Scanning) nhằm xác định các cổng đang mở, dò tìm hệ điều hành và phiên bản dịch vụ đang chạy (Banner Grabbing). Từ các thông tin này, tin tặc đối chiếu với cơ sở dữ liệu lỗ hổng bảo mật toàn cầu (CVE) để tìm ra các lỗi như thực thi mã từ xa (RCE) hoặc tràn bộ đệm nhằm chiếm quyền điều khiển thiết bị.

b. Các giải pháp phòng thủ và giám sát mạng

- Hệ thống IDS/IPS: * *IDS (Intrusion Detection System)*:* Hệ thống phát hiện xâm nhập hoạt động theo cơ chế bắt bản sao dữ liệu (Promiscuous

Mode), thực hiện phân tích và đưa ra cảnh báo (Alert) khi phát hiện dấu hiệu bất thường mà không làm ảnh hưởng đến tốc độ mạng đường trục.

- *IPS (Intrusion Prevention System)*: Hệ thống ngăn chặn xâm nhập được triển khai dạng nối tiếp trên đường truyền (In-line Mode). Khi phát hiện gói tin độc hại, IPS có khả năng chủ động can thiệp bằng cách thả (Drop) gói tin đó hoặc cấu hình tường lửa chặn ngay lập tức IP nguồn tấn công.
- Tường lửa thế hệ mới (Next-Generation Firewall - NGFW): Khác biệt hoàn toàn với tường lửa truyền thống (chỉ lọc dựa trên IP/Port ở Tầng 3 và 4), NGFW sở hữu khả năng kiểm tra gói tin sâu (Deep Packet Inspection - DPI) lên tới Tầng 7 (Application Layer). NGFW có thể nhận diện chính xác ứng dụng đang chạy (ví dụ: phân biệt được luồng Chat hay luồng File Transfer trong cùng ứng dụng Skype), tích hợp sẵn tính năng giải mã SSL/TLS, kiểm soát người dùng dựa trên Active Directory (Identity Awareness) và ngăn chặn mã độc (Antivirus/Anti-Spyware) thời gian thực.

1.2.3. Thuật toán và cơ chế an ninh mạng phục vụ VPN

a. Thuật toán mã hóa dòng và mã hóa khối

Để thiết lập kênh truyền bảo mật VPN (Virtual Private Network) qua môi trường Internet, hệ thống sử dụng hai nhóm thuật toán mật mã:

- Mã hóa đối xứng (Mã hóa khối - Block Cipher): Tiêu chuẩn vàng hiện nay là AES (Advanced Encryption Standard) với độ dài khóa 128-bit hoặc 256-bit. Dữ liệu được chia thành các khối 128-bit cố định và trải qua nhiều vòng biến đổi toán học bao gồm: Thay thế byte (SubBytes), Dịch hàng (ShiftRows), Trộn cột (MixColumns), và Cộng khóa vòng (AddRoundKey). AES đảm bảo dữ liệu được xáo trộn hoàn hảo và có tốc

độ xử lý phần cứng cực nhanh, phù hợp để mã hóa toàn bộ dữ liệu người dùng truyền qua đường ống VPN.

- Mã hóa bất đối xứng (Asymmetric Cipher): Thuật toán Diffie-Hellman (DH) hoặc RSA. Do mã hóa đối xứng AES yêu cầu hai đầu phải có chung một khóa bí mật, thuật toán Diffie-Hellman giải quyết bài toán này bằng cách cho phép hai thiết bị tự tính toán ra một khóa bí mật chung (Symmetric Key) thông qua kênh truyền công khai bằng các phép toán lũy thừa trên trường số nguyên lớn, đảm bảo kẻ nghe lén đường truyền không thể tính toán ngược lại được khóa này.

b. Thuật toán kiểm tra toàn vẹn và xác thực (Hàm băm & HMAC)

- Hàm băm an toàn SHA-2 (Secure Hash Algorithm 2 - SHA-256): Là hàm toán học một chiều (One-way Function) nhận đầu vào là gói tin có độ dài bất kỳ và sinh ra một chuỗi đại diện (Digest) có độ dài cố định 256-bit. SHA-256 sở hữu "hiệu ứng thác đổ" (Avalanche Effect): chỉ cần thay đổi 1 bit dữ liệu ở đầu vào, toàn bộ chuỗi băm đầu ra sẽ thay đổi hoàn toàn. Điều này giúp thiết bị nhận kiểm tra được tính toàn vẹn (Integrity) của gói tin mạng.
- HMAC (Hash-based Message Authentication Code): Để ngăn chặn cuộc tấn công thay đổi cả gói tin lẫn chuỗi băm (kẻ tấn công sửa đổi gói tin rồi tự tính lại chuỗi băm mới), HMAC thực hiện băm gói tin kết hợp với một khóa bí mật được chia sẻ trước (Preshared Key) giữa hai đầu thiết bị. Quy trình này đảm bảo tính xác thực nguồn gốc (Authentication): gói tin vừa không bị sửa đổi, vừa chắc chắn được gửi từ một đối tác hợp pháp nắm giữ khóa.

1.2.4. Kiến thức cơ sở về ngôn ngữ và công cụ giám sát mạng

a. Các công cụ mô phỏng và phân tích mạng chuyên dụng

- Cisco Packet Tracer / GNS3 / EVE-NG:
 - + *Cisco Packet Tracer*: Phần mềm giả lập trực quan của Cisco, tối ưu cho việc thiết kế mô hình mạng nhanh, cấu hình CLI cho Router/Switch/Firewall và kiểm thử luồng đi của gói tin thông qua chế độ Simulation thời gian thực.
 - + *GNS3 / EVE-NG*: Công cụ giả lập phần cứng thực tế bằng cách chạy trực tiếp các hệ điều hành mạng (IOS, ASA, Linux) trên các máy ảo (QEMU/KVM). Cho phép xây dựng các phòng thí nghiệm mạng an toàn với độ chính xác 100% so với thiết bị thật ngoài thực tế.
- Wireshark: Công cụ phân tích giao thức mạng (Packet Analyzer) hàng đầu thế giới. Hoạt động bằng cách bắt (Capture) các gói tin di chuyển qua card mạng, phân rã cấu trúc gói tin thành các tầng chi tiết (Ethernet, IP, TCP, HTTP...). Wireshark giúp người quản trị phát hiện các hành vi bất thường như tấn công quét cổng, kiểm tra các chuỗi dữ liệu nhạy cảm truyền ở dạng bản rõ hoặc phân tích mã độc dựa trên các hành vi kết nối C2 (Command and Control).

b. Các ngôn ngữ lập trình sử dụng phổ biến trong an toàn mạng

- Python: Ngôn ngữ lập trình cốt lõi của xu hướng Tự động hóa mạng (Network Automation) và DevSecOps.
 - .+. Sử dụng thư viện **Netmiko** hoặc **Paramiko** để viết mã tự động đẩy cấu hình an toàn (như cập nhật ACL, đổi mật khẩu hàng loạt) lên hàng trăm thiết bị mạng cùng lúc qua SSH.
 - .+. Sử dụng thư viện **Scapy** để tự tay định nghĩa, giả lập hoặc thao tác sâu vào cấu trúc từng tầng của gói tin mạng (Packet Crafting), phục

vụ cho việc kiểm thử xâm nhập (Penetration Testing) hoặc mô phỏng tấn công.

- Bash Shell / PowerShell: Ngôn ngữ kịch bản hệ thống mặc định trên Linux (Bash) và Windows (PowerShell). Được ứng dụng mạnh mẽ để viết các script tự động lọc, phân tích tệp tin nhật ký (Log Parser) từ Tường lửa hoặc Máy chủ dịch vụ (như trích xuất các IP có dấu hiệu Brute Force từ file [access.log](#)), sau đó tự động kích hoạt các tập lệnh cấu hình hệ thống để chặn các IP độc hại này ngay lập tức.

1.3. Nội dung nghiên cứu

1.3.1 Lý do chọn đề tài

Trong thời đại chuyển đổi số hiện nay, hệ thống mạng máy tính đóng vai trò quan trọng đối với hoạt động quản lý, sản xuất và kinh doanh của các doanh nghiệp. Đặc biệt đối với các công ty hoạt động trong lĩnh vực kỹ thuật và công nghệ, việc xây dựng một hệ thống mạng ổn định, hiệu quả và an toàn là yêu cầu thiết yếu nhằm đảm bảo quá trình trao đổi dữ liệu, vận hành các dịch vụ nội bộ và kết nối với khách hàng được thông suốt.

Tuy nhiên, cùng với sự phát triển của công nghệ thông tin, các nguy cơ mất an toàn thông tin ngày càng gia tăng như tấn công mạng, truy cập trái phép, đánh cắp dữ liệu, phát tán mã độc và nhiều hình thức tấn công khác. Những rủi ro này có thể gây ảnh hưởng nghiêm trọng đến hoạt động sản xuất kinh doanh, làm thất thoát dữ liệu quan trọng, giảm uy tín và gây thiệt hại về kinh tế cho doanh nghiệp.

Công ty Cổ phần Kỹ thuật và Công nghệ TMT là doanh nghiệp hoạt động trong lĩnh vực kỹ thuật và công nghệ, có nhu cầu sử dụng hệ thống mạng để phục vụ công tác quản lý, trao đổi thông tin và triển khai các dịch vụ công nghệ. Do đó, việc xây dựng một mô hình mạng an toàn với các giải pháp như phân chia VLAN, triển khai Firewall, thiết lập vùng DMZ, cấu hình ACL, VPN, DHCP Snooping, Port Security và các cơ chế bảo mật khác là hết sức cần thiết nhằm bảo vệ tài nguyên mạng và nâng cao khả năng quản trị hệ thống.

Xuất phát từ những yêu cầu thực tiễn đó, nhóm chúng em lựa chọn đề tài “Xây dựng mô hình mạng an toàn cho Công ty Cổ phần Kỹ thuật và Công nghệ TMT”. Thông qua đề tài, nhóm mong muốn vận dụng các kiến thức đã học về quản trị mạng và an toàn thông tin để thiết kế, triển khai và đánh giá một mô hình mạng doanh nghiệp đáp ứng các yêu cầu về hiệu năng, khả năng mở rộng và đặc biệt là tính bảo mật. Đồng thời, đề tài cũng giúp nhóm nâng cao kỹ năng thực hành trên môi trường mô phỏng, tạo tiền đề cho việc nghiên cứu và triển khai các hệ thống mạng thực tế trong tương lai.

1.3.2. Mục tiêu nghiên cứu

Đề tài được thực hiện với các mục tiêu chính sau:

1.3.3. Đối tượng và phạm vi nghiên cứu

1.3.4. Phương pháp nghiên cứu

Đề tài được triển khai dựa trên sự kết hợp của các phương pháp sau:

- Phương pháp nghiên cứu lý thuyết: Tổng hợp, phân tích và hệ thống hóa các tài liệu liên quan từ sách, giáo trình, các tiêu chuẩn chính thống (như DSS của NIST) và các nguồn tài liệu học thuật đáng tin cậy khác.

- Phương pháp thực nghiệm: Áp dụng lý thuyết để thiết kế, xây dựng và kiểm thử ứng dụng minh họa. Việc cài đặt thuật toán sẽ được kiểm chứng tính đúng đắn thông qua các bộ dữ liệu đầu vào cụ thể.

1.3.5. Ý nghĩa của đề tài

-

1.3.6. Kết cấu của đề tài

Báo cáo được kết cấu thành 03 chương:

- **Chương 1: Tổng quan** - Giới thiệu tổng quát về vấn đề nghiên cứu.
- **Chương 2: Kết quả nghiên cứu** - Trình bày toàn bộ nội dung lý thuyết trọng tâm về mô hình mạng an toàn và quá trình xây dựng ứng dụng minh họa.
- **Chương 3: Kết luận** - Tổng kết, đánh giá kết quả đạt được và đề xuất hướng phát triển tiếp theo.

Chương 2: Kết quả nghiên cứu

2.1. Nghiên cứu, tìm hiểu về mô hình mạng an toàn (Các thành phần chính của mô hình mạng an toàn, các công nghệ hỗ trợ)

Mô hình mạng an toàn (Secure Network Model) là kiến trúc mạng được thiết kế nhằm đảm bảo tính bí mật (Confidentiality), toàn vẹn (Integrity) và sẵn sàng (Availability) của dữ liệu và các dịch vụ trong hệ thống mạng. Mô hình này kết hợp nhiều giải pháp kỹ thuật và chính sách quản lý để ngăn chặn các mối đe dọa từ bên ngoài cũng như bên trong tổ chức.

Mục tiêu của mô hình mạng an toàn:

- Bảo vệ dữ liệu khỏi truy cập trái phép.
- Ngăn chặn các cuộc tấn công mạng.

- Đảm bảo tính liên tục của hoạt động kinh doanh.
- Kiểm soát và giám sát các truy cập trong hệ thống.
- Hỗ trợ khôi phục dữ liệu khi xảy ra sự cố

2.1.2. Các thành phần chính của mô hình mạng an toàn

a) Tường lửa (Firewall)

Trong mô hình mạng an toàn, Firewall được xem là tuyến phòng thủ đầu tiên giữa mạng doanh nghiệp và Internet. Mọi lưu lượng dữ liệu ra vào hệ thống đều phải đi qua Firewall trước khi được phép truy cập vào các tài nguyên bên trong mạng. Thiết bị này giúp giảm thiểu nguy cơ truy cập trái phép, ngăn chặn các cuộc tấn công từ bên ngoài và thực thi các chính sách bảo mật của doanh nghiệp.

Một số chức năng chính của Firewall bao gồm:

- Kiểm soát lưu lượng truy cập vào và ra khỏi mạng.
- Lọc các gói tin dựa trên địa chỉ IP, cổng và giao thức.
- Ngăn chặn các kết nối không hợp lệ.
- Ghi nhật ký và hỗ trợ giám sát hoạt động mạng.

Nhờ đó, Firewall trở thành thành phần không thể thiếu trong bất kỳ hệ thống mạng hiện đại nào.

b) Vùng mạng trung gian DMZ (Demilitarized Zone)

Không phải tất cả các máy chủ của doanh nghiệp đều nên được đặt trực tiếp trong mạng nội bộ. Đối với các dịch vụ cần cung cấp cho người dùng bên ngoài như website, email hoặc DNS, doanh nghiệp thường triển khai một vùng mạng riêng gọi là DMZ.

DMZ đóng vai trò là khu vực đệm giữa Internet và mạng nội bộ. Khi người dùng truy cập website của doanh nghiệp, yêu cầu sẽ được chuyển đến máy chủ đặt trong DMZ thay vì truy cập trực tiếp vào hệ thống bên trong. Điều này giúp hạn chế nguy cơ kẻ tấn công xâm nhập sâu hơn vào mạng nội bộ nếu máy chủ dịch vụ công cộng gặp sự cố bảo mật.

c) Mạng nội bộ (LAN)

Mạng LAN là nơi diễn ra các hoạt động làm việc hằng ngày của doanh nghiệp. Tại đây tập trung các thiết bị như:

- Máy tính nhân viên.
- Máy in mạng.
- Điện thoại IP.
- Các hệ thống quản lý nội bộ.

Để nâng cao mức độ bảo mật, mạng LAN thường được chia thành nhiều VLAN theo từng phòng ban. Ví dụ, phòng Kế toán, phòng Nhân sự và phòng Kỹ thuật có thể được đặt trong các VLAN khác nhau. Việc phân tách này giúp hạn chế truy cập trái phép giữa các bộ phận và giảm phạm vi ảnh hưởng nếu xảy ra sự cố an ninh mạng.

d) Hệ thống máy chủ (Server)

Máy chủ là trung tâm lưu trữ và xử lý dữ liệu của doanh nghiệp. Tùy theo chức năng, hệ thống có thể bao gồm máy chủ cơ sở dữ liệu, máy chủ ứng dụng, máy chủ quản lý người dùng hoặc máy chủ sao lưu.

Do chứa nhiều thông tin quan trọng, máy chủ thường được đặt trong khu vực mạng riêng với mức độ bảo vệ cao hơn so với các thiết bị thông thường. Ngoài việc triển khai các giải pháp bảo mật như phân quyền truy cập và cập nhật bản vá định kỳ, doanh nghiệp còn cần xây dựng cơ chế sao lưu dữ liệu để đảm bảo khả năng phục hồi khi xảy ra sự cố.

e) Hệ thống IDS/IPS

Bên cạnh việc ngăn chặn truy cập trái phép bằng Firewall, hệ thống mạng còn cần một cơ chế giám sát để phát hiện các hành vi bất thường.

IDS (Intrusion Detection System) có nhiệm vụ theo dõi lưu lượng mạng và cảnh báo khi phát hiện dấu hiệu tấn công. Trong khi đó, IPS (Intrusion Prevention System) được phát triển ở mức cao hơn khi có khả năng chủ động ngăn chặn các hành vi nguy hiểm ngay khi chúng xảy ra.

Ví dụ, khi hệ thống phát hiện một địa chỉ IP liên tục thực hiện các hành động dò quét cổng mạng, IPS có thể tự động chặn địa chỉ đó nhằm giảm thiểu rủi ro cho hệ thống.

f) Mạng riêng ảo VPN (Virtual Private Network)

Xu hướng làm việc từ xa khiến nhu cầu truy cập hệ thống doanh nghiệp qua Internet ngày càng tăng. Tuy nhiên, việc truyền dữ liệu trên môi trường Internet công cộng luôn tiềm ẩn nguy cơ bị nghe lén hoặc đánh cắp thông tin.

VPN được triển khai nhằm giải quyết vấn đề này bằng cách tạo ra một đường hầm truyền dữ liệu được mã hóa giữa người dùng và hệ thống doanh nghiệp. Nhờ đó, nhân viên có thể truy cập tài nguyên nội bộ từ bên ngoài mà vẫn đảm bảo tính bảo mật của dữ liệu.

Lợi ích của VPN:

- Bảo vệ dữ liệu khi truyền qua Internet.
- Hỗ trợ làm việc từ xa.
- Giảm nguy cơ đánh cắp thông tin đăng nhập.
- Đảm bảo kết nối an toàn đến hệ thống nội bộ.

g) Hệ thống giám sát bảo mật SIEM

Trong một hệ thống mạng doanh nghiệp, mỗi thiết bị đều tạo ra lượng lớn dữ liệu nhật ký (log) mỗi ngày. Nếu quản trị viên phải kiểm tra từng thiết bị riêng lẻ sẽ rất khó phát hiện các dấu hiệu tấn công.

Vì vậy, các doanh nghiệp thường triển khai hệ thống SIEM (Security Information and Event Management) để tập trung toàn bộ log về một nơi duy nhất.

SIEM thực hiện ba nhiệm vụ chính:

- Thu thập dữ liệu từ các thiết bị mạng.
- Phân tích và phát hiện các hành vi bất thường.
- Cảnh báo và hỗ trợ điều tra sự cố bảo mật.

Nhờ khả năng giám sát tập trung, SIEM giúp doanh nghiệp nâng cao hiệu quả quản lý an toàn thông tin.

h) Hệ thống sao lưu và phục hồi dữ liệu

Dữ liệu được xem là tài sản quan trọng nhất của doanh nghiệp. Những sự cố như hỏng ổ cứng, lỗi hệ thống hoặc tấn công ransomware đều có thể gây mất dữ liệu nghiêm trọng.

Để hạn chế rủi ro này, doanh nghiệp cần xây dựng hệ thống sao lưu dữ liệu định kỳ. Một nguyên tắc thường được áp dụng là mô hình **3-2-1**, bao gồm:

- 03 bản sao dữ liệu.
- 02 phương tiện lưu trữ khác nhau.
- 01 bản sao được lưu ở vị trí tách biệt.

Việc triển khai hệ thống Backup không chỉ giúp khôi phục dữ liệu khi có sự cố mà còn đảm bảo tính liên tục cho hoạt động của doanh nghiệp.

2.1.3. Các công nghệ hỗ trợ mô hình mạng an toàn

Để nâng cao hiệu quả bảo vệ hệ thống mạng, bên cạnh các thành phần chính, doanh nghiệp còn triển khai nhiều công nghệ hỗ trợ khác nhau. Các công nghệ này giúp tăng cường khả năng kiểm soát truy cập, bảo vệ dữ liệu và phát hiện các nguy cơ mất an toàn thông tin.

- VLAN (Virtual Local Area Network): Phân chia mạng vật lý thành nhiều mạng logic nhằm tăng cường quản lý và hạn chế truy cập trái phép giữa các phòng ban.

- ACL (Access Control List): Thiết lập các quy tắc cho phép hoặc từ chối lưu lượng truy cập giữa các thiết bị và phân vùng mạng.
- NAT (Network Address Translation): Chuyển đổi địa chỉ IP riêng thành địa chỉ IP công cộng, giúp tiết kiệm tài nguyên địa chỉ IPv4 và che giấu cấu trúc mạng nội bộ.
- Mã hóa dữ liệu (Encryption): Sử dụng các thuật toán như AES, RSA, SHA-256 hoặc TLS/SSL để bảo vệ dữ liệu trong quá trình lưu trữ và truyền tải.
- Xác thực đa yếu tố (Multi-Factor Authentication - MFA): Tăng cường bảo mật tài khoản bằng cách yêu cầu người dùng xác thực thông qua nhiều yếu tố khác nhau.
- Endpoint Security: Bảo vệ các thiết bị đầu cuối như máy tính, laptop và thiết bị di động trước các mối đe dọa từ virus, malware hoặc ransomware.
- Zero Trust Security: Mô hình bảo mật dựa trên nguyên tắc "Không tin tưởng mặc định, luôn xác minh", yêu cầu xác thực và kiểm tra quyền truy cập đối với mọi đối tượng trong hệ thống.
- VPN (Virtual Private Network): Thiết lập kết nối từ xa an toàn thông qua các kênh truyền dữ liệu được mã hóa.
- Hệ thống quản lý định danh và truy cập (Identity and Access Management - IAM): Quản lý tài khoản người dùng, phân quyền truy cập và kiểm soát danh tính trong hệ thống.
- Giám sát nhật ký và phân tích sự kiện bảo mật (Log Management & SIEM): Thu thập, lưu trữ và phân tích dữ liệu nhật ký để phát hiện sớm các dấu hiệu tấn công.

2.2. Các mô hình mạng an toàn sử dụng trong doanh nghiệp

2.3. Nghiên cứu mô hình mạng an toàn cho công ty CP kỹ thuật và công nghệ TMT

Thiết kế DMZ:

Cấu hình cho từng bộ phận:

- Web Server:

Desktop → IP Configuration:

IP Address	192.168.80.10
Mask	255.255.255.0
Gateway	192.168.80.1
DNS	192.168.80.30

Services → HTTP:

HTTP	ON
HTTPS	ON

- DNS Server:

Desktop → IP Configuration:

IP Address	192.168.80.30
Mask	255.255.255.0
Gateway	192.168.80.1

Services → DNS

Add Record:

Name	Address
www.tmtc.com	192.168.80.10
mail.tmtc.com	192.168.80.20

- Mail Server:

Desktop → IP Configuration:

IP Address	192.168.80.20
------------	---------------

Mask	255.255.255.0
Gateway	192.168.80.1

Services → Email

SMTP	ON
POP3	ON
Domain	tmtc.com

- Firewall 1:

Config → Interface:

Fa0/0: 10.10.10.2/30

Fa0/1: 192.168.80.1/24

Static: 200.200.200.0/24 via 10.10.10.1

- Firewall 2:

Config → Interface:

Fa0/0: 192.168.80.254/24

Fa0/1: 172.16.0.1/30

Static: 192.168.0.0/16 via 172.16.0.2, 0.0.0.0/0 via 192.168.80.1

- Router0:

Fa0/0: 10.10.10.1/30

Fa0/1: 200.200.200.1/24

Static: 192.168.80.0/24 via 10.10.10.2

ACL cần làm để đúng mô hình DMZ

Trên Firewall1:

Cho phép Internet truy cập Web:

access-list 100 permit tcp any host 192.168.80.10 eq 80

access-list 100 permit tcp any host 192.168.80.10 eq 443

Cho phép Mail:

access-list 100 permit tcp any host 192.168.80.20 eq 25

Cho phép DNS:

access-list 100 permit udp any host 192.168.80.30 eq 53

Chặn toàn bộ Internet vào LAN:

access-list 100 deny ip any 192.168.0.0 0.0.255.255

Kế hoạch địa chỉ IP:

Do công ty có 100-200 người dùng nên mỗi VLAN sử dụng: /24 (254 host)

Dễ mở rộng.

VLAN	Phòng ban	Network	Gateway
10	Ban Giám đốc	192.168.10.0/24	192.168.10.1
20	Kế toán	192.168.20.0/24	192.168.20.1
30	Nhân sự	192.168.30.0/24	192.168.30.1
40	Kinh doanh	192.168.40.0/24	192.168.40.1
50	IT	192.168.50.0/24	192.168.50.1
60	Server Farm	192.168.60.0/24	192.168.60.1
70	Guest WiFi	192.168.70.0/24	192.168.70.1
80	DMZ	-	192.168.80.1
99	Management	192.168.99.0/24	192.168.99.1

Server Farm:

Thiết bị	IP
Database Server	192.168.60.10
File Server	192.168.60.20
Backup Server	192.168.60.30
Domain Controller	192.168.60.40

DMZ:

Thiết bị	IP
Web Server	192.168.80.10

Mail Server	192.168.80.20
DNS Server	192.168.80.30

Phân quyền truy cập:

Phòng ban	Chính sách bảo mật
Giám đốc	Truy cập toàn bộ hệ thống
Kế toán	Truy cập Database kế toán. Không truy cập dữ liệu nhân sự.
Nhân sự	Truy cập hệ thống nhân sự. Không truy cập dữ liệu kế toán.
Kinh doanh	Truy cập Website và CRM. Không truy cập Database.
IT	Quản trị toàn bộ thiết bị mạng.
Server	
Guest WiFi	Chỉ được truy cập Internet. Không được truy cập bất kỳ VLAN nội bộ nào.

2.4. Thực nghiệm mô hình mạng an toàn cho công ty cổ phần kỹ thuật và công nghệ TMT.

2.4.1. Giới thiệu công cụ hỗ trợ mô phỏng: Cisco Packet Tracer

Tổng quan công cụ: Cisco Packet Tracer là phần mềm mô phỏng mạng trực quan và mạnh mẽ do Cisco Systems phát triển, hỗ trợ thiết kế, cấu hình và giám sát các luồng dữ liệu trong hệ thống mạng.

Lý do lựa chọn: Công cụ này cung cấp đầy đủ các thiết bị phần cứng giả lập như Router, Switch Layer 2/3, Máy chủ (Servers), Máy trạm (PCs) và đặc biệt là thiết bị tường lửa chuyên dụng Cisco ASA Firewall.

Tính năng hỗ trợ: Cho phép giả lập toàn diện các giao thức định tuyến, cấu hình danh sách kiểm soát truy cập (ACL), thiết lập các dịch vụ mạng thông dụng và kiểm tra trực quan luồng đi của gói tin thông qua chế độ Simulation (Mô phỏng thời gian thực).

2.4.2. Mục tiêu của hệ thống thực nghiệm

Xác thực kiến trúc: Kiểm tra tính đúng đắn và khả năng vận hành ổn định của mô hình mạng an toàn đã thiết kế trên lý thuyết cho doanh nghiệp.

Phân tách vùng bảo mật: Đảm bảo luồng dữ liệu giữa các phân vùng Inside (Mạng nội bộ), DMZ (Vùng lưu trữ Server công cộng) và Outside (Internet công cộng) được kiểm soát nghiêm ngặt qua tường lửa.

Đảm bảo tính sẵn sàng: Kiểm tra khả năng tự động cấu hình và phản hồi của các dịch vụ cốt lõi khi có yêu cầu truy cập từ người dùng trong và ngoài hệ thống.

Tối ưu hóa chính sách: Phát hiện sớm các lỗ hổng cấu hình hoặc xung đột chính sách bảo mật trước khi triển khai trên hạ tầng vật lý thực tế.

2.4.3. Thiết kế kịch bản chương trình.

a. Kịch bản Vận hành Hạ tầng Lõi và Cấp phát Dịch vụ Nội bộ

Hệ thống khởi đầu bằng việc thiết lập và kiểm tra tính thông suốt của hạ tầng mạng cốt lõi tại thiết bị trung tâm **SW-CORE** và **FW-INSIDE**. Kịch bản này tập trung vào việc cấp phát địa chỉ IP tự động thông qua giao thức DHCP cho tất cả các máy tính (Data) và các thiết bị điện thoại IP (Voice) thuộc các phòng ban như Giám đốc, Kế toán, Nhân sự, Kinh doanh và IT. Khi các thiết bị khởi động hoàn tất và nhận đúng dải IP theo phân hoạch VLAN, luồng công việc sẽ tiến hành kiểm tra kết nối nội bộ bằng lệnh **ping** chéo giữa các phòng để xác nhận tính năng định tuyến Inter-VLAN. Đồng thời, hệ thống thực hiện kiểm tra dịch vụ VoIP bằng cách thiết lập các cuộc gọi thử nghiệm giữa các phòng ban, đảm

bảo tín hiệu thoại rõ ràng và các số máy nhánh (Line) hiển thị chính xác theo cấu hình trên tổng đài.

b. Kịch bản Quản lý và Phân quyền Truy cập Máy chủ DMZ

Đối với vùng máy chủ công cộng DMZ (bao gồm Web, Mail và DNS Server), kịch bản vận hành chia làm ba luồng dữ liệu rõ rệt nhằm kiểm tra các chính sách an ninh mạng. Luồng thứ nhất cho phép người dùng từ ngoài Internet đi qua mạng **Cloud-PT** và **FW-OUTSIDE** để truy cập vào địa chỉ IP Public của Web Server hoặc gửi thư đến Mail Server. Luồng thứ hai đảm bảo người dùng nội bộ (như phòng Giám đốc hay Kinh doanh) khi gõ tên miền công ty sẽ được **DNS Server** phân giải chính xác và **FW-INSIDE** cấp phép đi vào vùng DMZ để sử dụng dịch vụ. Luồng cuối cùng và cũng là quan trọng nhất về mặt bảo mật, đó là kiểm tra tính năng chặn ngược dòng; hệ thống sẽ giả lập tình huống nếu các máy chủ DMZ bị tấn công, mọi nỗ lực kết nối hoặc **ping** từ vùng DMZ quay ngược trở lại các PC phòng ban hoặc vùng **Server Farm** nội bộ đều phải bị Firewall chặn đứng hoàn toàn.

c. Kịch bản Bảo mật Vùng Server Farm và Chính sách Ra Internet

Vùng máy chủ nội bộ **Server Farm** (màu tím) chứa các dữ liệu cốt lõi của doanh nghiệp, do đó kịch bản kiểm thử thiết lập quyền truy cập nghiêm ngặt dựa trên danh sách kiểm soát (ACL). Theo kịch bản, chỉ có các thiết bị thuộc phòng IT và Ban Giám đốc mới có quyền kết nối toàn diện (như FTP, SSH) để quản trị hệ thống, trong khi các phòng ban khác bị giới hạn hoặc cấm truy cập hoàn toàn tùy thuộc vào vị trí chuyên môn. Song song với đó, luồng dữ liệu đi ra Internet từ mạng nội bộ sẽ được kiểm tra thông qua cơ chế dịch biên địa chỉ PAT (Dynamic NAT) trên cặp đôi Firewall. Kịch bản tổng thể sẽ vận hành việc lọc gói tin để đảm bảo các phòng ban được cấp phép có thể kết nối ra Internet bình thường,

đồng thời áp dụng các quy tắc chặn đối với các phòng ban đặc thù (như phòng Kế toán để tránh thất thoát dữ liệu) hoặc giới hạn truy cập theo khung giờ hành chính.

d. Kịch bản các phòng.

- Phòng Giám Đốc:

- *Phòng Kế Toán*:

- *Phòng Nhân Sự*:

- *Phòng Kinh Doanh*:

- *Phòng IT*:

Bộ phận IT được bố trí trong VLAN 50 và được cấp quyền truy cập đầy đủ tới toàn bộ hệ thống mạng nhằm phục vụ công tác quản trị, bảo trì và xử lý sự cố. Thông qua cơ chế ACL được cấu hình trên thiết bị SW-CORE, người dùng thuộc VLAN 50 có thể truy cập đến tất cả các VLAN khác, bao gồm Ban Giám đốc, Kế toán, Nhân sự, Kinh doanh và Server Farm. Nhờ đó, nhân viên IT có thể thực hiện các hoạt động giám sát, kiểm tra kết nối, cấu hình thiết bị mạng cũng như quản lý các máy chủ của doanh nghiệp.

Bên cạnh đó, giải pháp DHCP Snooping được triển khai trên các switch nhằm ngăn chặn các DHCP Server giả mạo xuất hiện trong mạng nội bộ. Khi máy tính của bộ phận IT kết nối vào hệ thống, thiết bị sẽ chỉ nhận địa chỉ IP từ DHCP Server hợp lệ, đảm bảo tính chính xác và an toàn trong quá trình cấp phát địa chỉ mạng.

Ngoài ra, hệ thống VPN được cấu hình trên thiết bị biên để hỗ trợ nhân viên IT truy cập từ xa thông qua Internet. Sau khi xác thực thành công, người dùng sẽ được cấp địa chỉ IP VPN và có thể truy cập vào các tài nguyên nội bộ như Server Farm, Mail Server, Web Server và các thiết bị mạng để thực hiện công tác quản trị. Việc sử dụng VPN giúp đảm bảo dữ liệu được mã hóa trong quá trình truyền tải, nâng cao tính bảo mật và hỗ trợ xử lý sự cố từ xa một cách hiệu quả.

Kết quả kiểm thử cho thấy bộ phận IT có thể truy cập thành công tới toàn bộ tài nguyên trong hệ thống, nhận địa chỉ IP hợp lệ từ DHCP Server và kết nối từ xa qua VPN một cách an toàn, đáp ứng yêu cầu quản trị của doanh nghiệp

2.4.4. Giải pháp bảo mật trong hệ thống thực nghiệm

Để bảo vệ toàn diện hệ thống mạng thực nghiệm trước các nguy cơ tấn công, các giải pháp kỹ thuật sau được áp dụng:

- Kiểm soát truy cập tầng biên (Access Control List - ACL): Sử dụng Extended ACL để chặn triệt để các gói tin giả mạo IP (IP Spoofing) từ Internet và giới hạn các giao thức quản trị nhạy cảm (như SSH, Telnet) chỉ dành cho máy của Admin.
- Cơ chế biên dịch địa chỉ mạng (NAT/PAT): Cấu hình Dynamic NAT hoặc PAT trên Tường lửa/Router biên để che giấu hoàn toàn sơ đồ địa chỉ IP Private của mạng Inside khi đi ra ngoài Internet, giảm thiểu nguy cơ bị quét cổng dò tìm điểm yếu.
- Bảo mật hạ tầng Switch (Port Security & DHCP Snooping): Kích hoạt Port Security trên Switch lớp truy cập để giới hạn số lượng địa chỉ MAC kết nối vào một cổng, đồng thời bật DHCP Snooping nhằm ngăn chặn kẻ tấn công cắm DHCP Server giả mạo vào mạng nội bộ.

- Mã hóa và xác thực nâng cao: Thay thế hoàn toàn giao thức Telnet bằng SSH v2 với thuật toán mã hóa mạnh để quản trị thiết bị từ xa; áp dụng chính sách mật khẩu phức tạp cho toàn bộ hệ thống Server dịch vụ.

2.4.5. Mô phỏng, triển khai thực nghiệm.

- a. Thiết kế mô hình mạng an toàn
 - Sơ đồ mạng tổng thể
 - Thiết kế VLAN
 - Thiết Kế DMZ
 - Thiết kế Server Farm
 - Kế hoạch địa chỉ IP
- b. Triển khai các giải pháp bảo mật
 - Cấu hình ACL

```
SW-CORE#show run | section interface Vlan
interface Vlan1
  no ip address
  shutdown
interface Vlan10
  mac-address 0060.7069.0b01
  ip address 192.168.10.1 255.255.255.0
  ip helper-address 192.168.60.30
  ip access-group ACL-GD in
interface Vlan20
  mac-address 0060.7069.0b02
  ip address 192.168.20.1 255.255.255.0
  ip helper-address 192.168.60.30
  ip access-group ACL-KT in
interface Vlan30
  mac-address 0060.7069.0b03
  ip address 192.168.30.1 255.255.255.0
  ip helper-address 192.168.60.30
  ip access-group ACL-NS in
interface Vlan40
  mac-address 0060.7069.0b04
  ip address 192.168.40.1 255.255.255.0
  ip helper-address 192.168.60.30
  ip access-group ACL-KD in
interface Vlan50
  mac-address 0060.7069.0b05
  ip address 192.168.50.1 255.255.255.0
  ip helper-address 192.168.60.30
  ip access-group ACL-IT in
interface Vlan60
  mac-address 0060.7069.0b06
  ip address 192.168.60.1 255.255.255.0
interface Vlan70
  mac-address 0060.7069.0b07
  no ip address
  ip helper-address 192.168.60.30
SW-CORE#
```

- Firewall
- VPN

```
!  
ip local pool VPNPOOL 10.10.10.1 10.10.10.20  
ip classless  
ip route 192.168.0.0 255.255.0.0 172.16.0.2  
ip route 0.0.0.0 0.0.0.0 192.168.80.1  
ip route 192.168.50.0 255.255.255.0 192.168.254.2  
ip route 192.168.10.0 255.255.255.0 192.168.254.2  
ip route 192.168.20.0 255.255.255.0 192.168.254.2  
ip route 192.168.30.0 255.255.255.0 192.168.254.2  
ip route 192.168.40.0 255.255.255.0 192.168.254.2  
ip route 10.10.10.0 255.255.255.252 192.168.80.1  
ip route 200.200.200.0 255.255.255.0 192.168.80.1  
ip route 192.168.60.0 255.255.255.0 192.168.254.2  
!  
ip flow-export version 9
```

- Cấu hình Port Security
- DHCP Snooping

```
SW-GIAMDOC#show ip dhcp snooping  
Switch DHCP snooping is enabled  
DHCP snooping is configured on following VLANs:  
10  
Insertion of option 82 is enabled  
Option 82 on untrusted port is not allowed  
Verification of hwaddr field is enabled  
Interface                Trusted      Rate limit (pps)  
-----  
FastEthernet0/24         yes         unlimited
```

```
SW-KETOAN#show ip dhcp snooping  
Switch DHCP snooping is enabled  
DHCP snooping is configured on following VLANs:  
20  
Insertion of option 82 is enabled  
Option 82 on untrusted port is not allowed  
Verification of hwaddr field is enabled  
Interface                Trusted      Rate limit (pps)  
-----  
FastEthernet0/24         yes         unlimited
```

```
SW-NHANSU#show ip dhcp snooping
Switch DHCP snooping is enabled
DHCP snooping is configured on following VLANs:
30
Insertion of option 82 is enabled
Option 82 on untrusted port is not allowed
Verification of hwaddr field is enabled
Interface                Trusted    Rate limit (pps)
-----
FastEthernet0/24         yes      unlimited
```

```
SW-KINHDOANH#show ip dhcp snooping
Switch DHCP snooping is enabled
DHCP snooping is configured on following VLANs:
40
Insertion of option 82 is enabled
Option 82 on untrusted port is not allowed
Verification of hwaddr field is enabled
Interface                Trusted    Rate limit (pps)
-----
FastEthernet0/24         yes      unlimited
```

```
SW-IT#show ip dhcp snooping
Switch DHCP snooping is enabled
DHCP snooping is configured on following VLANs:
50
Insertion of option 82 is enabled
Option 82 on untrusted port is not allowed
Verification of hwaddr field is enabled
Interface                Trusted    Rate limit (pps)
-----
FastEthernet0/24         yes      unlimited
```

- Phân quyền truy cập

CHƯƠNG 3: KẾT LUẬN VÀ BÀI HỌC KINH NGHIỆM

3.1. Kiến thức, kỹ năng đã học được trong quá trình thực hiện đề tài

Trong quá trình thực hiện đề tài “Xây dựng mô hình mạng an toàn cho Công ty Cổ phần Kỹ thuật và Công nghệ TMT”, nhóm đã nghiên cứu, tìm hiểu và vận dụng nhiều kiến thức chuyên ngành về mạng máy tính và an toàn thông tin. Những kiến thức và kỹ năng đạt được bao gồm

Về kiến thức chuyên môn

- Hiểu rõ quy trình phân tích yêu cầu và thiết kế hệ thống mạng cho doanh nghiệp.
- Nắm vững nguyên tắc phân chia mạng bằng VLAN nhằm tăng hiệu quả quản lý và nâng cao tính bảo mật.
- Hiểu và vận dụng các kỹ thuật định tuyến, chuyển mạch trong hệ thống mạng doanh nghiệp.

- Nắm được nguyên lý hoạt động của Firewall và các cơ chế kiểm soát truy cập mạng.
- Hiểu cách xây dựng vùng DMZ để bảo vệ các máy chủ cung cấp dịch vụ công cộng.
- Tìm hiểu và triển khai các cơ chế bảo mật như ACL (Access Control List), Port Security, DHCP Snooping và VPN.
- Hiểu được vai trò của hệ thống máy chủ như Web Server, Mail Server, File Server và Database Server trong mô hình mạng doanh nghiệp.
- Nắm được các nguyên tắc phân quyền truy cập giữa các phòng ban nhằm đảm bảo an toàn dữ liệu.

Về kỹ năng thực hành

- Kỹ năng thiết kế sơ đồ mạng doanh nghiệp trên Cisco Packet Tracer.
- Kỹ năng cấu hình thiết bị mạng như Router, Switch và Firewall.
- Kỹ năng xây dựng kế hoạch địa chỉ IP và phân chia mạng con phù hợp với quy mô doanh nghiệp.
- Kỹ năng cấu hình VLAN, Trunking và Inter-VLAN Routing.
- Kỹ năng cấu hình ACL để kiểm soát quyền truy cập giữa các phòng ban.
- Kỹ năng cấu hình VPN nhằm bảo đảm kết nối từ xa an toàn.
- Kỹ năng kiểm tra, đánh giá và xử lý các lỗi phát sinh trong quá trình mô phỏng.
- Kỹ năng làm việc nhóm, phân công công việc và quản lý tiến độ thực hiện đề tài.

3.2. Bài học kinh nghiệm

Trong quá trình nghiên cứu và xây dựng mô hình mạng an toàn cho doanh nghiệp, nhóm đã rút ra nhiều bài học kinh nghiệm quý báu:

- Cần khảo sát kỹ yêu cầu thực tế của doanh nghiệp trước khi tiến hành thiết kế hệ thống mạng.
- Việc phân chia VLAN hợp lý giúp tăng hiệu quả quản lý và hạn chế nguy cơ truy cập trái phép giữa các bộ phận.
- Chính sách bảo mật cần được xây dựng theo nguyên tắc cấp quyền tối thiểu, chỉ cho phép người dùng truy cập đúng tài nguyên cần thiết.
- ACL là công cụ quan trọng trong việc kiểm soát luồng dữ liệu và bảo vệ tài nguyên nội bộ.
- Việc kết hợp nhiều giải pháp bảo mật như Firewall, VPN, DHCP Snooping và Port Security giúp nâng cao khả năng phòng chống tấn công mạng.
- Thiết kế hệ thống cần đảm bảo tính mở rộng để đáp ứng nhu cầu phát triển trong tương lai của doanh nghiệp.
- Kiểm thử thường xuyên giúp phát hiện sớm các lỗi cấu hình và các lỗ hổng bảo mật.
- Làm việc nhóm hiệu quả và phân công nhiệm vụ rõ ràng góp phần quan trọng vào việc hoàn thành đề tài đúng tiến độ.

3.3. Đề xuất về tính khả thi của chủ đề nghiên cứu, những thuận lợi và khó khăn

3.3.1. Tính khả thi của đề tài

Đề tài “Xây dựng mô hình mạng an toàn cho Công ty Cổ phần Kỹ thuật và Công nghệ TMT” có tính khả thi cao do:

- Các công nghệ và giải pháp được sử dụng đều là những công nghệ phổ biến trong môi trường doanh nghiệp hiện nay.
- Cisco Packet Tracer cung cấp môi trường mô phỏng đầy đủ để triển khai và kiểm tra hoạt động của hệ thống.

- Các kỹ thuật bảo mật như VLAN, ACL, Firewall, VPN, DHCP Snooping và Port Security đều có thể áp dụng trực tiếp trong thực tế.
- Mô hình được xây dựng có khả năng mở rộng khi số lượng người dùng và thiết bị tăng lên.
- Chi phí triển khai thực tế có thể được điều chỉnh linh hoạt tùy theo quy mô và nhu cầu của doanh nghiệp.

3.3.2. Thuận lợi

- Có nhiều tài liệu, giáo trình và nguồn tham khảo về thiết kế mạng doanh nghiệp và an toàn thông tin.
- Cisco Packet Tracer hỗ trợ đầy đủ các chức năng mô phỏng cần thiết cho đề tài.
- Các thành viên trong nhóm có sự phối hợp và hỗ trợ lẫn nhau trong quá trình thực hiện.
- Đề tài có tính ứng dụng thực tiễn cao, phù hợp với kiến thức đã được học trong học phần An toàn và Bảo mật thông tin.
- Dễ dàng kiểm tra và đánh giá kết quả thông qua môi trường mô phỏng.

3.3.3. Khó khăn

- Việc thiết kế một hệ thống mạng vừa đáp ứng yêu cầu hoạt động vừa đảm bảo an toàn thông tin đòi hỏi nhiều kiến thức chuyên môn.
- Quá trình xây dựng chính sách ACL và phân quyền truy cập cần được tính toán cẩn thận để tránh ảnh hưởng đến hoạt động của các phòng ban.
- Việc cấu hình và kiểm tra các cơ chế bảo mật như VPN, DHCP Snooping và Port Security tương đối phức tạp.
- Packet Tracer vẫn có những hạn chế nhất định so với môi trường triển khai thực tế.

- Khó đánh giá đầy đủ các nguy cơ tấn công mạng thực tế chỉ thông qua mô phỏng.
- Thời gian thực hiện đề tài còn hạn chế nên chưa thể triển khai thêm các giải pháp bảo mật nâng cao như IDS/IPS, xác thực đa yếu tố (MFA) hoặc hệ thống giám sát tập trung.

3.4. Kết luận

Đề tài “Xây dựng mô hình mạng an toàn cho Công ty Cổ phần Kỹ thuật và Công nghệ TMT” đã giúp nhóm vận dụng hiệu quả các kiến thức về mạng máy tính và an toàn thông tin vào việc thiết kế một hệ thống mạng doanh nghiệp hoàn chỉnh. Mô hình được xây dựng đáp ứng các yêu cầu về phân chia mạng, quản lý người dùng, phân quyền truy cập và bảo vệ tài nguyên quan trọng của doanh nghiệp thông qua các giải pháp bảo mật như VLAN, ACL, Firewall, VPN, Port Security và DHCP Snooping.

Thông qua quá trình thực hiện đề tài, nhóm không chỉ nâng cao kiến thức chuyên môn mà còn phát triển các kỹ năng thực hành, làm việc nhóm và giải quyết vấn đề. Mặc dù mô hình mới được triển khai trong môi trường mô phỏng, kết quả đạt được cho thấy tính khả thi và khả năng áp dụng vào thực tế doanh nghiệp.

Do còn hạn chế về thời gian và kinh nghiệm, đề tài vẫn còn một số nội dung có thể tiếp tục nghiên cứu và hoàn thiện trong tương lai. Nhóm rất mong nhận được những ý kiến đóng góp từ giảng viên để đề tài ngày càng hoàn thiện và có giá trị ứng dụng cao hơn.

Tài liệu tham khảo

(Sắp xếp theo ngôn ngữ: Việt, Anh, Pháp, Đức, Nga...)

[1]. Nguyễn Xuân Dũng, *Bảo mật thông tin – Mô Hình và ứng dụng*, NXB thống kê, 2009.

[2]. Bùi Doãn Khanh, Nguyễn Đình Thúc, *Mã hóa thông tin – Lý thuyết và ứng dụng*, NXB Lao động xã hội, 2011.

Tài liệu tham khảo

(Sắp xếp theo ngôn ngữ: Việt, Anh, Pháp, Đức, Nga...)

[1]. Nguyễn Xuân Dũng, *Bảo mật thông tin – Mô Hình và ứng dụng*, NXB thống kê, 2009.

[2]. Bùi Doãn Khanh, Nguyễn Đình Thúc, *Mã hóa thông tin – Lý thuyết và ứng dụng*, NXB Lao động xã hội, 2011.

[3]. William Stallings, *Cryptography and Network Security Principles and Practices*, Fourth Edition, Prentice Hall, 2005.

...

[n]. <http://www.hhs.com>

(thời gian truy cập: 15h00, ngày 27/10/2024)

Phụ lục 1: Chương trình Java

...

Phụ lục 2: Chương trình C#

...

Quy định trình bày báo cáo:

Lề trên: 2,5 cm Lề dưới: 2 cm

Lề trái: 3,5 cm lề phải: 2 cm

Nội dung báo cáo trình bày: Các đoạn báo cáo căn đều 2 bên

Phông chữ: Time New Roman

Cỡ chữ: 13 (hoặc 14)

Dãn dòng: Multiple 1.3

Đánh số trang ở giữa, phía trên đầu mỗi trang giấy (phần Header)

Số lượng trang báo cáo: từ 40 - 60 trang